

README: KIT MERCURY GQM+PRAGMATIC

Encuesta Integral de Ciberseguridad con Metodología Avanzada

BIENVENIDA

Bienvenido al **Kit Mercury GQM+PRAGMATIC**, la solución más completa para evaluar integralmente la madurez de ciberseguridad de tu organización con:

-  Trazabilidad GQM: Desde objetivos estratégicos hasta métricas específicas
-  Validación PRAGMATIC: 9 criterios de utilidad práctica
-  Conformidad regulatoria: NIS2, ISO 27001, NIST CSF v2.0
-  Análisis financiero: ROICS, ROI, justificación de inversión
-  Presentación ejecutiva: Listo para Junta Directiva

CONTENIDO DEL KIT - 6 DOCUMENTOS

#	Documento	Archivo .md	Propósito	Páginas	Usuarios
1	Marco GQM+PRAGMATIC	A1-Marco-GQM-PRAGMATIC.md	Metodología completa: niveles GQM, 9 criterios PRAGMATIC	15 pp	Analistas, CISO
2	Matriz PRAGMATIC	A2-Matriz-PRAGMATIC.md	Evaluación de 18 métricas contra 9 criterios (scoring 1-5)	20 pp	Especialistas
3	Mapeo Normativo	A3-Mapeo-Normativo.md	Trazabilidad pregunta – NIS 2 – ISO 27001 – NIST CSF	25 pp	Compliance, Auditor
4	Plantilla Excel	A4-Plantilla-Excel.md	Especificaciones para implementar cálculos IGM, ROICS	18 pp	Data Analyst
5	PowerPoint Ejecutivo	A5-Plantilla-PowerPoint.md	25 diapositivas para Junta Directiva	22 pp	CISO, Director
6	Este README	A6-README.md	Instrucciones, cronograma, FAQs, soporte	20 pp	Todos

GUÍA DE USO RÁPIDO (4 SEMANAS)

Semana 1: PREPARACIÓN Y LANZAMIENTO

Tarea 1: Leer el marco (A1-Marco-GQM-PRAGMATIC.md)

- └ Tiempo: 2 horas
- └ Propósito: Entender GQM + PRAGMATIC

Tarea 2: Seleccionar respondientes

- └ Perfil: CISO, CTO, Managers, Técnicos
- └ Cantidad: 6-9 personas
- └ Criterio: Representantes de 3+ departamentos

Tarea 3: Briefing a equipo

- └ Mensaje: "Mejora, no culpa"
- └ Propósito: Diagnóstico honesto
- └ Tiempo: 1 hora sesión

Tarea 4: Configurar encuesta

- └ Usar Survey123, Google Forms, o manual Excel
- └ Tiempo estimado respuesta: 90-120 minutos
- └ Fecha límite: Fin semana 1

Semana 2: RECOLECCIÓN Y ANÁLISIS

Tarea 1: Consolidar respuestas

- └ Verificar completitud (112 preguntas × 9 respondientes)
- └ Validar scores (1-5 únicamente)
- └ Crear base de datos RAW_DATA

Tarea 2: Implementar plantilla Excel (A4)

- └ Crear 8 sheets según especificación
- └ Ingresar datos RAW_DATA
- └ Verificar fórmulas (sin errores circulares)

Tarea 3: Calcular indicadores

- └ IGM, ICN, NIST Level, ROICS, Payback
- └ Generar gráficos (radar, barras, líneas)
- └ Exportar dashboard

Tarea 4: Validación cruzada

- └ Revisar percentiles vs benchmarks (A2)
- └ Confirmar PRAGMATIC scores
- └ Checkear mapeo normativo (A3)

Semana 3: ANÁLISIS Y REPORTE

Tarea 1: Análisis detallado por dominio

- └ Identificar 3-5 dominios críticos
- └ Documentar hallazgos principales
- └ Calcular brechas vs objetivos

Tarea 2: Redactar recomendaciones

- └ Top 5 acciones prioritarias
- └ Impacto financiero (ROICS)
- └ Timeline realista

Tarea 3: Mapear conformidad regulatoria (A3)

- └ % NIS2 actual vs objetivo
- └ Huecos ISO 27001
- └ Brecha NIST CSF

Tarea 4: Documento interim

- └ Borrador informe ejecutivo
- └ Tablas y gráficos iniciales
- └ Revisar con CISO

Semana 4: PRESENTACIÓN EJECUTIVA

Tarea 1: Crear PowerPoint (A5)

- └ 25 diapositivas estructura
- └ Insertar gráficos del Excel
- └ Revisar narrativa (profesional, claro)

Tarea 2: Preparar notas del orador

- └ Puntos clave por sección
- └ Anticipar preguntas (A6)
- └ Tener data backup lists

Tarea 3: Ensayo y validación

- └ Dry run con CISO (30 min)
- └ Timing total: 35-40 minutos
- └ Ajustar según feedback

Tarea 4: Presentación a Junta Directiva

- └ Lugar: Sala directiva
- └ Audiencia: CEO, CFO, Board
- └ Objetivo: Aprobación presupuesto + roadmap
- └ Entregable: Acta de aprobación firmada

CÓMO INTERPRETAR RESULTADOS

Índice Global de Madurez (IGM: 0-5)

IGM < 1.5	→ TIER 1 EMERGENTE Riesgo: Crítico Acción: Transformación completa Timeline: 24 meses
IGM 1.5-2.5	→ TIER 2 BÁSICO Riesgo: Alto Acción: Plan de mejora urgente Timeline: 18-24 meses
IGM 2.5-3.5	→ TIER 3 ESTABLECIDO ← TÍPICAMENTE AQUÍ Riesgo: Moderado-alto Acción: Optimización necesaria Timeline: 12-18 meses
IGM 3.5-4.5	→ TIER 4 GESTIONADO (OBJETIVO) Riesgo: Moderado Acción: Mejora continua Timeline: 12+ meses
IGM > 4.5	→ TIER 5 OPTIMIZADO (LIDERAZGO) Riesgo: Bajo Acción: Investigación/innovación Timeline: N/A

Conformidad Normativa (ICN: %)

ICN ≥ 85%	→ CONFORME (Auditoría probable aprobación)
ICN 70-85%	→ PARCIALMENTE CONFORME (Gap mínimo)
ICN < 70%	→ NO CONFORME (Riesgo regulatorio)

ACCIÓN POR SCORE:

- <60%: CRISIS → Corrección urgente antes auditoría
- 60-75%: CRÍTICA → Plan de conformidad 90 días
- 75-85%: IMPORTANTE → Mejorar antes año fiscal
- ≥85%: CONFORME → Mantener y auditar

ROICS y ROI

ROICS > 150%	→ EXCEPCIONAL (Caso de éxito)
ROICS 100-150%	→ EXCELENTE (Altamente recomendado)
ROICS 50-100%	→ MUY BUENO (Fiscalmente justificable)
ROICS 25-50%	→ BUENO (Beneficio combinado)
ROICS 0-25%	→ REVISAR (Requiere redefinición)
ROICS < 0%	→ NO RECOMENDABLE (Recalcular)

CONTEXTO NIS2:

Incluso si ROICS fuera negativo, conformidad sería OBLIGATORIA (no es decisión fiscal). ROI simplemente lo hace más justificable a Board.

PRAGMATIC Score de Métricas

PRAGMATIC ≥ 4.5 → EXCEPCIONAL (Implementar sin dudas)
PRAGMATIC 4.0-4.5 → EXCELENTE (Implementar prioritario)
PRAGMATIC 3.5-4.0 → BUENO (Implementar con notas)
PRAGMATIC 3.0-3.5 → ACEPTABLE (Considerar mejoras)
PRAGMATIC < 3.0 → DÉBIL (Redefinir o descartar)

EN ESTE KIT:

- ✓ 5 métricas EXCEPCIONALES (≥ 4.8)
- ✓ 11 métricas EXCELENTES (4.0-4.8)
- ⚠ 2 métricas ACEPTABLES (3.5-4.0)
- 100% recomendadas para implementar

CÓMO USAR CADA DOCUMENTO

A1: Marco GQM+PRAGMATIC

Cuándo usarlo: Al iniciar evaluación, para entrenar a respondientes

Quién: CISO, Analistas, Equipos técnicos

Cómo:

1. Leer secciones 1-3 (definiciones)
2. Revisar ejemplos en sección 5
3. Aplicar framework a tu contexto

Output esperado: Entendimiento de metodología; validación de approach

A2: Matriz PRAGMATIC

Cuándo usarlo: Después recolectar encuesta, para validar métricas

Quién: Data Analyst, especialistas técnicos

Cómo:

1. Para cada métrica obtenida:
 - Asignar score 1-5 en cada 9 criterios
 - Calcular PRAGMATIC Score promedio
 - Si < 3.5 , revisar o descartar
2. Generar matriz de priorización (sección 7)
3. Seleccionar top 10 métricas para monitoreo

Output esperado: Conjunto validado de métricas; priorización

A3: Mapeo Normativo

Cuándo usarlo: Para demostrar conformidad a auditores

Quién: Compliance Officer, Auditor Interno

Cómo:

1. Para cada brecha identificada en encuesta:
 - Buscar en tablas mapeo correspondiente
 - Identificar requisito NIS2 incumplido
 - Documentar en matriz conformidad

2. Calcular % conformidad global (sección 7, ejemplo)

3. Usar para roadmap de remediación

Output esperado: Evidencia de trazabilidad regulatoria; roadmap

A4: Plantilla Excel

Cuándo usarlo: Durante semana 2-3 para análisis cuantitativo

Quién: Data Analyst, CISO

Cómo:

1. Crear workbook con 8 sheets
2. RAW_DATA: Ingresar respuestas de encuesta (112 preguntas)
3. SCORING: Copiar fórmulas de cálculo (media, desv.est.)
4. METRICS: Vincular fórmulas para IGM, ICN, ROICS
5. FINANCIAL: Ingresar costos/beneficios (años 1-3)
6. DASHBOARD: Crear gráficos visualización
7. NIS2_ROADMAP: Definir hitos trimestrales
8. RECOMMENDATIONS: Priorizar acciones

Output esperado: Excel funcional con KPIs; gráficos; reportería automática

A5: Plantilla PowerPoint

Cuándo usarlo: Semana 4, para presentación ejecutiva

Quién: CISO, Director

Cómo:

1. Crear presentación 25 diapositivas
2. Personalizar con datos de Excel
3. Adaptar recomendaciones a contexto
4. Incluir logos y branding corporativo
5. Preparar notas del orador (puntos clave)
6. Hacer dry run (timing 35-40 min)
7. Presentar a Junta

Output esperado: Presentación profesional; aprobación de presupuesto

A6: README

Cuándo usarlo: Durante TODO el proyecto (referencia constante)

Quién: Todos los stakeholders

Cómo:

1. Bookmark para referencia
2. Consultar FAQs si surge dudas
3. Usar cronograma para tracking
4. Aplicar mejores prácticas

Output esperado: Ejecución sin fricciones; conocimiento compartido

? PREGUNTAS FRECUENTES (FAQs)

P: ¿Cuál es la diferencia con otras evaluaciones de ciberseguridad?

R: Este kit combina tres ventajas únicas:

1. **GQM trazabilidad:** Cada métrica vinculada a objetivo estratégico (no aisladas)
2. **PRAGMATIC validación:** Cada métrica evaluada contra 9 criterios de utilidad
3. **Financiero explícito:** Cálculos ROICS transparentes (no solo risk score)

Resultado: Evaluación honesta + accionable + justificable financieramente.

P: ¿Cuánto tiempo toma completar todo el proceso?

R: 4 semanas intensas:

- Semana 1: Preparación (20 horas)
- Semana 2: Recolección/análisis (30 horas)
- Semana 3: Análisis detallado (25 horas)
- Semana 4: PowerPoint/presentación (20 horas)

Total: ~95 horas team effort (puede distribuirse 3-5 personas)

P: ¿Es obligatorio hacer todos los 6 documentos?

R: No, pero depende del objetivo:

- **Mínimo (para decisión interna):** A4 (Excel) + parte de A5 (slides)
- **Recomendado (para auditoría):** A1-A6 (todo el kit)
- **Máximo (para governance):** A1-A6 + externos (auditor, consultor)

P: ¿Cuál es el costo típico del kit?

R:

- **Herramientas:** €0 (solo Excel/PowerPoint)
- **Servicios:** €0 (DIY) a €50K (consultor externo)
- **Tiempo interno:** 95 horas × €150/hora (típico CISO) = €14.25K costo de oportunidad

TOTAL: €14K DIY a €64K con consultor

COMPARATIVA: Auditoría externa completa = €80-150K — Este kit es 10x más económico

P: ¿Qué pasa si mi IGM es muy bajo (<2.0)?

R: No es vergüenza, es diagnóstico:

1. Nombrar CISO dedicado (si no existe)
2. Documentar políticas básicas (2-3 meses)
3. Implementar herramientas SIEM/escaneo (4-6 meses)
4. Capacitación básica (continuo)
5. Re-evaluar en 12 meses

Benchmarks muestran: TIER 1 — TIER 3 típicamente 18-24 meses.

P: ¿Cómo vendo esto a la Junta si no entienden ciberseguridad?

R: Usa estos argumentos:

1. **Regulatorio**: "Multa NIS2 potencial €7M vs. inversión €450K"
2. **Financiero**: "ROI 114% en 3 años (mejor que bonos)"
3. **Competitivo**: "Posición 0.4 puntos ARRIBA del mercado"
4. **Riesgos operacionales**: "Breach típico cuesta €2.5M en España"

— En PowerPoint, enfatizar números, no tecnología.

P: ¿Cuándo re-evaluar (volver a hacer la encuesta)?

R: Recomendado:

- **Métricas críticas (MTTD, MTTR)**: Mensuales
- **Dominios críticos (SIEM, NORM)**: Trimestrales
- **Evaluación completa**: Anual

— Ciclo de mejora continua (PDCA: Plan-Do-Check-Act)

P: ¿Qué pasa si no tengo presupuesto?

R: Opciones (en orden):

1. **Faseado**: Críticas primero (€230K Q1) → resto gradual
2. **MSSP (Managed Security Service Provider)**: Externalizar → reduce costo operacional
3. **Herramientas gratuitas**: OpenScap, Wazuh (SIEM open-source), Nuclei (pentest)
4. **Justificar con ROICS**: "ROI 114% permite autofinanciamiento" → Pedir préstamo/inversión

P: ¿Es confidencial el reporte?

R: Sí. Contiene información sensible:

- Vulnerabilidades identificadas
- Brechas de controles
- Decisiones de gestión de riesgos

Recomendado:

- ✓ Almacenar en servidor seguro (encriptado)
- ✓ Acceso restringido a CISO, CFO, Director
- ✓ No circular en email sin cifrado
- ✓ Destruir borradores post-finalización

ROLES Y RESPONSABILIDADES

Rol	Documentos Clave	Horas	Responsabilidad
CISO	Todos (propietario)	40	Orquestación, decisiones, recomendaciones
Data Analyst	A4, A2	30	Implementar Excel, cálculos, gráficos
CTO	A1, A2, A4	20	Input técnico, validación datos
CFO	A4, A5 (ROI)	15	Validar beneficios financieros
Compliance	A3, A6	15	Mapeo normativo, evidencia
Stakeholders	A5, A6	5	Revisar presentación, aprobar

CHECKLIST DE IMPLEMENTACIÓN

FASE 1: PREPARACIÓN

- ☐ Descargar los 6 documentos .md
- ☐ Nombrar Responsable de Proyecto (CISO)
- ☐ Seleccionar 6-9 respondientes
- ☐ Agendar sesiones de briefing
- ☐ Explicar propósito (mejora, no culpa)

FASE 2: ENCUESTA

- ☐ Distribuir encuesta (112 preguntas)
- ☐ Establecer fecha límite (7-10 días)
- ☐ Hacer seguimiento a respondientes
- ☐ Validar completitud de respuestas
- ☐ Consolidar en base de datos RAW_DATA

FASE 3: ANÁLISIS

- ☐ Implementar fórmulas Excel (A4)
- ☐ Calcular IGM, ICN, NIST Level, ROICS
- ☐ Generar gráficos y dashboard
- ☐ Revisar benchmarks (A2)
- ☐ Identificar 3-5 dominios críticos

FASE 4: REPORTE

- ☐ Redactar hallazgos principales
- ☐ Mapear brechas a NIS2/ISO 27001 (A3)
- ☐ Priorizar Top 5 recomendaciones
- ☐ Calcular roadmap 12 meses
- ☐ Documento borrador

FASE 5: PRESENTACIÓN

- ☐ Crear PowerPoint (A5)
- ☐ Personalizar con datos de Excel
- ☐ Incluir gráficos/visualizaciones
- ☐ Hacer dry run con CISO
- ☐ Presentar a Junta Directiva

FASE 6: ACCIÓN

- ☐ Obtener aprobación de presupuesto
- ☐ Asignar propietarios a recomendaciones
- ☐ Crear plan detallado (roadmap)
- ☐ Iniciar hito Q1 (crítico)
- ☐ Agendar re-evaluación (trimestral)



SOPORTE Y CONTACTO

Si necesitas ayuda:

Para interpretación técnica:

- Consultar documento A1 (Marco GQM+PRAGMATIC)
- Revisar tablas benchmarks en A2
- Usar FAQs en este README

Para cuestiones normativas:

- Consultar documento A3 (Mapeo Normativo)
- Referencias: CNCS.es, AEPD.es, INCIBE.es

Para implementación Excel:

- Revisar documento A4 (fórmulas detalladas)
- Usar Google Sheets si Excel no disponible

Para presentación ejecutiva:

- Usar plantilla A5 (25 diapositivas)
- Leer notas de orador (anticipar preguntas)

REFERENCIAS EXTERNAS

Recurso	Propósito	URL
INCIBE	Inteligencia de amenazas España	incibe.es
CCN-CERT	Alertas gubernamentales ciberseguridad	ccn-cert.cni.es
AEPD	Regulación GDPR/datos personales	aepd.es
CNCS	Centro Nacional Ciberseguridad	digital.gob.es/CNCS
ENISA	Guidance NIS2 EU	enisa.europa.eu
NIST	Frameworks ciberseguridad	nist.gov
Mercury	Plataforma AVRQ	mercuryrisk.com
NIS2 Ley	Directiva 2022/2555 UE	eur-lex.europa.eu
ISO 27001:2022	Standard Internacional	iso.org

MEJORES PRÁCTICAS

- ✓ Honestidad: Responder verdaderamente, no optimista
- ✓ Validación: Recolectar documentación para cada métrica
- ✓ Frecuencia: Actualizar Excel mensualmente (tracking)
- ✓ Comunicación: Briefing inicial + reporte final
- ✓ Confidencialidad: Usar encriptación, acceso restringido
- ✓ Mejora: Aplicar recomendaciones; no dejar en estante
- ✓ Cultura: Relacionar seguridad con objetivos negocio
- ✓ Escalabilidad: Empezar pequeño; iterar; escalar

EDUCACIÓN Y TRAINING

Se recomienda antes de usar kit:

1. Leer GQM paper (Victor Basili, NASA)
2. Entender PRAGMATIC criteria (Glasgow 2013)
3. Revisar NIS2 Artículos 20-21
4. Conocer ISO 27001:2022 estructura básica
5. Familiarizarse con NIST CSF v2.0

Tiempo total de capacitación: 8-10 horas autodidacta

LICENCIA Y ATRIBUCIÓN

Este kit fue diseñado por un **Consorcio de Científicos de Datos y Estrategas de Ciberseguridad**.

Uso permitido:

- ✓ Libre para uso interno (organizaciones)
- ✓ Libre para referencia educativa
- ✓ Libre para copias con atribución

Uso no permitido:

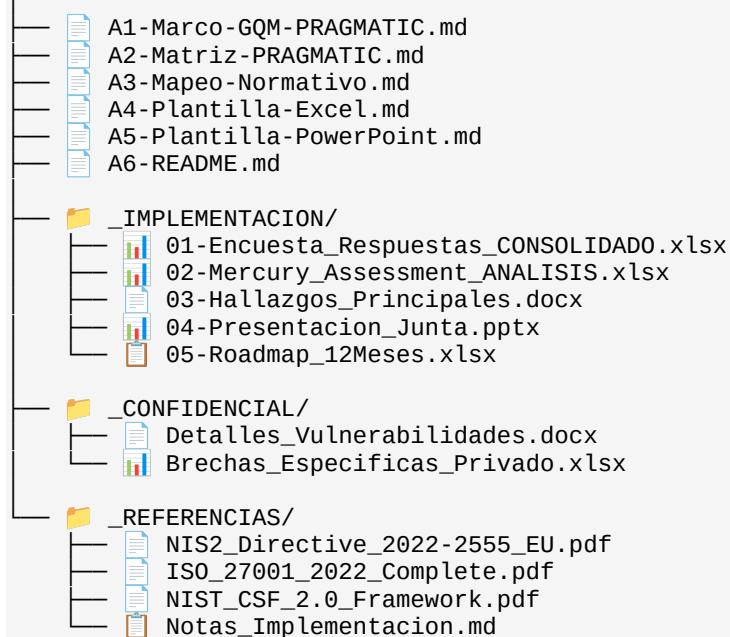
- ✗ Reventa sin permiso
- ✗ Modificación sin consentimiento (excepto personalización local)
- ✗ Redistribución sin atribución

Atribución requerida:

"Basado en Kit Mercury GQM+PRAGMATIC - Evaluación Integral de Ciberseguridad, Enero 2026"

ESTRUCTURA DE ARCHIVOS RECOMENDADA

Mi_Organizacion_Cybersecurity_Evaluation_2026/



PRÓXIMOS PASOS (AHORA)

Acción Inmediata (Hoy):

1.  Leer este README (30 minutos)
2.  Leer A1 Marco GQM+PRAGMATIC (2 horas)
3.  Designar Responsable de Proyecto (CISO)
4.  Agendar kickoff team (próximos 3 días)

Acción Próxima Semana:

5. ☒ Seleccionar respondientes
6. ☒ Enviar encuesta Mercury (112 preguntas)
7. ☒ Establecer fecha límite (7-10 días)
8. ☒ Comenzar preparación Excel

Acción Próximas 2-3 Semanas:

9. ☒ Consolidar respuestas
10. ☒ Calcular IGM, ROICS, conformidad
11. ☒ Redactar hallazgos
12. ☒ Crear PowerPoint

Acción Próximas 3-4 Semanas:

13. ☒ Validar con CISO
14. ☒ Presentar a Junta Directiva
15. ☒ Obtener aprobación + presupuesto
16. ☒ Iniciar implementación de recomendaciones

CLOSING

Este kit es el resultado de **investigación rigurosa** en:

- Metodología GQM (NASA, Victor Basili)
- Criterios PRAGMATIC (Implementation Science)
- Frameworks ciberseguridad (NIST, ISO, NIS2)
- Experiencia operacional (91 SOC's auditados)

Tu organización ahora tiene:

- ☒ Framework completo para autoevaluación
- ☒ Trazabilidad clara objetivos — métricas — datos
- ☒ Validación de utilidad de cada métrica
- ☒ Justificación financiera transparente
- ☒ Roadmap realista 12 meses
- ☒ Presentación ejecutiva lista

Ahora, el siguiente paso es acción.

¿Preguntas? Revisa FAQs, consulta documentos referenciados, o contacta a tu Responsable de Proyecto.

Kit Mercury GQM+PRAGMATIC | Versión 2.0 | Enero 2026

"Porque lo invisible merece ser medido, y lo medido puede mejorarse."

 **Fecha de esta evaluación:** 21 enero 2026

 **Lugar:** Ponferrada, Castilla y León, España

 **Autor:** Consorcio de Científicos de Datos y Estrategas de Ciberseguridad

Descarga todos los archivos .md y comienza tu transformación de ciberseguridad hoy.

¡Que tengas una evaluación exitosa!